

EVIDENCE ROOM

AP Agent Governance Framework

Accountability, controls, and earned autonomy

Tier 2 · Professional

Operating Evidence · Not legal, tax, or accounting advice

AP Agent Governance Framework

Product: Evidence Room — AP Agent OS · Professional **Document ID:** ER-AP-GOV-001 **Version:** 1.0

Audience: CFO, Controller, Head of AP / Shared Services, Internal Audit, IT Security, Finance Transformation

Purpose: Define the non-negotiable operating rules under which AI agents may participate in Accounts Payable.

1. Governing principles

- 1 Human accountability first.** Every agent output that affects money, vendors, postings, or control decisions has a named human owner. Agents do not hold fiduciary responsibility.
- 2 Responsibility is earned, not assumed.** Agents operate on a defined ladder (L0 Observe → L4 Managed autonomy). Full autonomy is never the default and is never applied to payment authorisation.
- 3 Payment authorisation stays human.** No agent may approve, release, or execute payment. Agents may prepare proposals and flag risks; humans authorise.
- 4 Controls before convenience.** Throughput gains do not justify weakened segregation of duties, missing evidence, or unreviewed high-risk actions.
- 5 Evidence over assertion.** Claims of accuracy, savings, or control effectiveness require measurable evidence retained under the retention schedule in §18.
- 6 Fail closed on material risk.** Ambiguous, low-confidence, or policy-violating agent outputs route to human review — not silent auto-post.

These principles bind all 16 agents in the AP Agent OS stack and any custom agents derived from them.

2. Human accountability

2.1 Accountability model

Executive sponsor (CFO / Controller)	Approves agent programme scope, risk appetite, and autonomy ceiling; owns residual risk
AP Process Owner	Owns process design, exception taxonomy, and agent charters for AP end-to-end
Agent Owner (named per agent)	Day-to-day performance, exception queues, control operation, escalation
Control Owner	Design and operating effectiveness of specific preventive/detective controls
Model / Platform Owner (IT / FinTech)	Access, model versions, logging, environment separation, vendor contracts
Internal Audit	Independent assurance; not operational owner of agents

2.2 Non-transferable human duties

The following remain exclusively human and cannot be delegated to an agent at any autonomy level:

- Payment authorisation and bank-file release
- Vendor master bank-detail changes (initiate may be assisted; approve remains human)
- Override of hard control blocks (duplicate payment block, SoD conflict, policy breach)
- Sign-off on period close assertions that rely on agent-prepared workpapers

- Acceptance of residual risk after a control failure or model incident

2.3 RACI for agent-assisted work

Every agent charter must include a RACI for: intake, recommendation, preparation of posting/proposal, execution within guardrails, escalation, evidence retention, and KPI reporting. Ambiguous ownership is treated as a control deficiency until resolved.

3. Segregation of duties (SoD)

3.1 Core SoD rules for agent-assisted AP

Invoice posting vs payment authorisation	Must not be the same human; agents cannot bridge this gap
Vendor master change vs payment proposal	Separation required; agent may flag but not approve both
Exception clearance vs original document creation	Same individual must not clear their own induced exception without secondary review when amount/policy thresholds apply
Agent configuration change vs production execution	Model/prompt/workflow changes require change control separate from operational AP staff where practical
Audit log administration vs operational agent ownership	Log integrity administered by IT/security; AP cannot alter historical agent logs

3.2 Agent-specific SoD implications

- Agents that **prepare** journals, payment proposals, or vendor communications must not be configured to **approve** the same artefact.
- The AP Manager / Orchestrator agent may sequence work and surface conflicts; it must not resolve SoD conflicts by auto-approving.
- Where an agent recommends an action that would create an SoD conflict if a human accepted both sides, the system must block or force dual approval.

3.3 Evidence

SoD matrices (human + agent roles), conflict reports, override logs with dual approval, and periodic SoD certification (§20).

4. Least privilege

4.1 Access principles

- Agents receive the **minimum** system entitlements required for their charter (read vs write, entity scope, document type, amount band).
- Prefer read-only plus human-triggered write until L3 is formally approved for that agent and entity.
- No shared “super-agent” service account spanning ERP write, bank portals, and vendor master without compensating controls and named owners.
- Secrets (API keys, service credentials) stored in enterprise secret management; rotated on schedule and on personnel change.

4.2 Data minimisation

Prompts and retrieval contexts include only fields needed for the task. Full GL history, payroll, or unrelated PII must not be injected into agent context by default.

4.3 Environment separation

Development, shadow, pilot, and production agent configurations are separated. Production credentials are not used for exploratory prompt testing.

5. Approval boundaries

5.1 Autonomy levels (binding)

L0 Observe	Log and summarise only	Dashboards, watchlists	Any write or external send
L1 Recommend	Propose action for human decision	Ranked exceptions, suggested codes	Auto-post, auto-email to supplier
L2 Prepare	Draft artefacts for human submit	Draft journal, draft supplier reply, draft payment proposal line	Submit/post/send without human
L3 Execute within guardrails	Act inside pre-approved rules	Post low-risk coded invoices under amount/match thresholds; send templated follow-ups	Payment release; master-data approve; policy overrides
L4 Managed autonomy	Broader execution with intensified monitoring	Expanded L3 scope by entity/category after certification	Payment authorisation; never default

5.2 Threshold design

Approval boundaries are defined by combinations of: amount, match confidence, vendor risk tier, document completeness, entity, and exception type. Thresholds are documented in the Agent Control Matrix and change-controlled.

5.3 Escalation

Breach of confidence threshold, policy rule, SoD conflict, or anomaly score routes to the named human queue with reason codes. Silent drop of escalations is a severity-1 incident.

6. Role-based access control (RBAC)

6.1 Role families

AP Operator	Work queues, view agent recommendations, action L1–L2 items assigned to them
AP Supervisor	Queue reassignment, threshold exception review within policy, KPI views

AP Manager / Process Owner	Charter edits (draft), autonomy promotion proposals, scorecard acceptance
Controller / Finance leadership	Autonomy ceiling approval, risk acceptance, programme KPIs
IT / Platform admin	Deploy configs, manage connectors, secret rotation — not operational AP approval
Internal Audit / Compliance	Read-only evidence, logs, configs; no operational queue clearance
Vendor / external	No direct agent console access

6.2 Joiner–mover–leaver

Access provisioning follows HR events. Agent console and service-account access is reviewed on role change and terminated on exit (§19). Privileged roles require MFA.

6.3 Cross-entity and multi-ERP

RBAC scopes agents and humans to legal entities and ERP instances. Cross-entity visibility requires explicit grant and logging.

7. Data privacy

7.1 Data classes in AP agent context

Personal data	Supplier contact names, emails, employee names on T&E;	Lawful basis, minimisation, retention limits
Financial confidential	Invoice amounts, bank details, payment proposals	Need-to-know; encrypt in transit/at rest per enterprise standard
Special category	Rare in AP; if present (e.g. medical vendor notes)	Exclude from model context unless Legal approves
Credentials	Bank account numbers, tax IDs	Mask in UI/logs where feasible; never in prompt dumps to unmanaged tools

7.2 Processing rules

- Prefer on-enterprise or contractually governed model endpoints.
- Do not paste production AP data into consumer AI tools.
- Document international transfers and subprocessors in the vendor/model risk register (§21).
- Honour data subject requests via enterprise privacy process; agents do not independently delete audit evidence required by retention policy.

8. Confidential information

8.1 Classification

Agent inputs/outputs inherit the confidentiality of source systems (typically Internal or Confidential). Payment proposal packs, vendor disputes, and fraud investigations are treated as Confidential.

8.2 Handling rules

- Confidential agent outputs travel only on approved channels.
- Screenshots and exports for workshops use anonymised or synthetic data unless under NDA and need-to-know.
- Prompt libraries and few-shot examples must be scrubbed of live vendor names, bank details, and employee identifiers before sharing outside the control environment.

8.3 Third parties

Consultants and vendors accessing agent consoles sign confidentiality terms aligned with finance data handling. Access is time-bound and logged.

9. Prompt injection and adversarial input

9.1 Threat model (AP-specific)

Untrusted text enters agents via invoice OCR, email bodies, PDF annotations, supplier portal messages, and statement files. Adversaries may attempt to instruct the agent to: ignore match rules, alter bank details, approve exceptions, or exfiltrate data into outbound messages.

9.2 Required controls

Input isolation	Treat document/email text as data, not instructions; system prompts and tool schemas are privileged
Instruction hierarchy	Policy and tool constraints outrank document content
Allowlisted actions	Agents may only call approved tools with schema validation
Sensitive-field protection	Bank detail / remittance changes require human workflow outside free-text agent writeback
Outbound sanitisation	Supplier emails generated by agents use templates; free-form generation requires human send at L≤2
Anomaly detection	Flag outputs that conflict with ERP master data or policy

9.3 Testing

Prompt-injection test cases are part of UAT and periodic red-team samples (see Testing pack). Failures block autonomy promotion.

10. Hallucination and fabrication risk

10.1 Risk statement

Large language models may invent PO numbers, GRNs, GL codes, policy citations, or “confirmations” that do not exist in source systems. In AP, fabricated references can cause misposting, incorrect supplier communication, or false assurance.

10.2 Mandatory mitigations

- **Grounding:** Prefer retrieval from ERP/AP systems of record over model memory.

- **Citation:** Recommendations that cite documents must include system IDs verifiable in the ERP.
- **No silent invention:** If required fields are missing, agent returns “insufficient data” / exception — not a guessed value — for material fields (vendor ID, bank, tax, amount, PO, GRN).
- **Confidence & abstention:** Below threshold → escalate.
- **Human verification** for any L1–L2 output used in external communication or posting preparation until accuracy gates are met.

10.3 Prohibited behaviours

Agents must not invent audit evidence, falsely assert three-way match, or claim regulatory compliance conclusions.

11. Output validation

11.1 Validation layers

- 1 **Schema validation** — required fields, types, enumerations
- 2 **Business-rule validation** — match tolerances, tax logic hooks, duplicate keys, SoD
- 3 **Cross-system reconciliation** — agent proposal vs ERP query result
- 4 **Sampling / QA** — human review of statistically or risk-weighted samples
- 5 **Posting confirmation** — verify ERP acceptance and resulting document status

11.2 Dual control for high-impact outputs

Payment proposals, mass exception clearances, and close packs require human attestation checklists before use in decision-making.

11.3 Defect handling

Invalid outputs are logged as defects with severity, root cause (prompt, data, model, integration, process), and corrective action. Recurring defect classes feed Root Cause Agent and change backlog.

12. Audit logs

12.1 Minimum log content (per agent action)

- Timestamp (UTC), agent ID, version/hash of prompt & workflow config
- Actor (service identity) and initiating human (if any)
- Input references (document IDs), not necessarily full payloads
- Decision / recommendation / action taken
- Confidence / rule path where applicable
- Tools invoked and key parameters (sensitive values masked)
- Escalation / override flag and approver
- Correlation ID linking to ERP transaction IDs when write occurs

12.2 Integrity and access

Logs are append-only (or WORM-equivalent), access-controlled, and retained per §18. AP operators cannot edit historical logs. Clock sync follows enterprise NTP standards.

12.3 Auditability tests

Internal Audit may request reconstruction of “why did the agent recommend X?” for sampled items. Inability to reconstruct is a control failure.

13. Version control

13.1 Controlled artefacts

Under version control (Git or approved ALM): agent charters, prompts/system instructions, tool schemas, business rules, threshold tables, exception taxonomies, evaluation datasets, and deployment manifests.

13.2 Versioning rules

- Semantic or dated version IDs on every production agent config
- Immutable tags for releases used in audit periods
- Diff review required before production promotion
- Link scorecard periods to the agent versions then in force

13.3 Forbidden practice

Editing production prompts directly in a live console without change ticket, peer review, and version bump.

14. Model changes

14.1 Change types

Patch / provider silent update	Underlying model revision	Monitor quality dashboards; regression sample
Major model swap	New foundation model or vendor	Full regression + shadow comparison before cutover
Parameter change	Temperature, max tokens, retrieval settings	Change control; re-validate accuracy gates
Embedding / index rebuild	New vector index for policies	Integrity checks; sample retrieval QA

14.2 Model risk controls

- Inventory of models, providers, regions, and data flows (§21)
- Baseline evaluation set frozen per agent before go-live
- Dual-run (old vs new) in shadow for material changes
- Rollback plan with time-to-restore target
- Contractual notice where providers allow; assume silent change possible and monitor

15. Workflow changes

15.1 Scope

Changes to queues, escalation paths, match tolerances, approval matrices, email templates, and orchestration logic (including AP Manager / Orchestrator routing).

15.2 Change process

- 1 Impact assessment (control, SoD, KPI, volume)
- 2 Update charter / control matrix / thresholds
- 3 Test in non-production (§16)
- 4 Shadow or limited pilot if behaviour changes materially
- 5 Approval by Process Owner (+ Controller for autonomy or payment-adjacent changes)

- 6 Release notes and training update
- 7 Post-implementation review within agreed window

Emergency changes follow incident process (§17) with expedited documentation within 72 hours.

16. Testing

16.1 Required test types before production write access

Unit / rule tests	Business rules and validators
Scenario scripts	Golden-path and exception paths per agent
Adversarial / injection	Prompt injection and malformed documents
Integration	ERP/AP automation connectors
Shadow comparison	Agent vs human historical decisions
UAT	Business acceptance with named sign-off
Regression	On each material release

16.2 Exit criteria (illustrative — set locally)

Accuracy, false positive/negative, and escalation correctness gates defined in the KPI Scorecard and Shadow/Pilot/UAT pack must be met for the target autonomy level. Meeting gates does not guarantee future performance; monitoring continues.

16.3 Test data

Prefer anonymised production samples or synthetic data with realistic edge cases. Live supplier emails must not be sent from test environments.

17. Release management

17.1 Release train

- Scheduled releases preferred over continuous unaudited tweaks
- Release checklist: version tags, test evidence, control matrix update, rollback plan, communications
- Production promotion restricted to Platform Owner role

17.2 Autonomy promotion as a release

Moving an agent from $L_n \rightarrow L_{n+1}$ is a formal release requiring: scorecard evidence, control owner sign-off, executive approval if crossing into L3/L4 or expanding payment-adjacent scope, and updated RBAC if needed.

17.3 Rollback

Every release defines rollback to prior version within an agreed RTO. Rollback drills are periodic for critical agents (Matching, Duplicate & Anomaly, Payment Proposal Review).

18. Incident response

18.1 Incident classes (examples)

Sev-1	Incorrect mass posting; suspected data exfiltration; payment proposal corruption; log tampering
Sev-2	Elevated false match rate; SoD bypass; prompt-injection success in production
Sev-3	Single erroneous recommendation caught before posting; connector blip with no data loss
Sev-4	Cosmetic / reporting-only defects

18.2 Response steps

- 1 Detect & triage (severity, scope, ongoing risk)
- 2 Contain (disable write tools, revert to L0/L1, revoke credentials if needed)
- 3 Eradicate / correct (fix data, reverse erroneous posts via standard AP procedures)
- 4 Recover (restore service at reduced autonomy if required)
- 5 Post-incident review (root cause, control gaps, action owners, due dates)
- 6 Notify per policy (Internal Audit, Privacy, Cyber, affected process owners)

18.3 Payment-adjacent incidents

Any incident touching payment proposals, bank details, or duplicate-pay risk escalates immediately to Treasury/AP leadership regardless of initial severity label.

19. Override and fallback

19.1 Override

Human override of agent recommendations is expected and logged. Pattern analysis of overrides informs model/rule improvement — overrides are not punished.

Forced override of **hard controls** (e.g. duplicate block) requires dual approval and reason codes; single-person override is prohibited for hard controls.

19.2 Fallback modes

Model/provider outage	Queue holds; human standard process; read-only dashboards if available
Accuracy gate breach	Drop autonomy level immediately for affected agent/entity
Integration failure	Stop writes; preserve audit trail of failed attempts
Suspected compromise	Disable agent identities; rotate secrets; investigate

Business Continuity (§20) defines maximum tolerable downtime for agent-assisted paths vs pure manual AP.

20. Business continuity planning (BCP)

20.1 Assumptions

AP must continue if agents are unavailable. Agents are accelerators, not single points of failure for invoice processing or payment runs.

20.2 BCP requirements

- Documented manual (or non-AI automation) procedures for intake, match, exception, and payment proposal
- Recovery time objectives for agent platform vs ERP (ERP is primary)
- Periodic tabletop: “agents offline for N days during month-end”
- Critical spreadsheets/workpapers not solely embedded in agent memory

20.3 Crisis communications

Named contacts for Process Owner, Platform Owner, and executive sponsor; status page or finance ops channel for prolonged outages.

21. Evidence retention

21.1 Retention classes

Agent decision logs	Align to financial record retention (often 7+ years) or local statute
Prompt/workflow versions linked to postings	Align to financial record retention
UAT / release packs	At least through subsequent two audit cycles
Incident records	Per enterprise incident policy
Scorecards / sampling worksheets	Align to management review and audit needs

21.2 Completeness

Retention applies to evidence supporting postings and control operation — not indefinite storage of full raw OCR blobs if not required; follow legal hold when applicable.

21.3 Export for audit

Ability to export immutable evidence packs (period, agent, sample IDs, versions, outcomes) without altering source logs.

22. Access termination

22.1 Triggers

Leaver events, role changes removing AP duties, contractor end dates, vendor offboarding, compromised credentials, prolonged inactivity beyond policy.

22.2 Actions

- Disable human console access same day as HR notification for leavers
- Rotate shared/service credentials the individual could have known
- Reassign open agent-queue ownership
- Confirm no standing approval delegates remain active

22.3 Evidence

Termination tickets, access review screenshots/exports, secret rotation records.

23. Periodic certification

23.1 Cadence (illustrative — calibrate locally)

User access review (agent console + service accounts)	Quarterly	IT + AP Manager
SoD conflict certification	Quarterly / semi-annual	Control Owner + Audit support
Agent autonomy re-certification	Semi-annual or on scorecard breach	Process Owner + Controller
Control matrix attestation	Semi-annual	Control Owners
Model/vendor risk review	Semi-annual or on material change	Platform Owner + Risk
BCP / fallback drill	Annual	Process Owner

23.2 Outcomes

Pass, pass-with-actions, or fail (autonomy freeze / rollback). Failures escalate to executive sponsor.

24. Vendor and model risk

24.1 Inventory

Maintain a register of: model providers, orchestration platforms, OCR vendors, iPaaS connectors, and subprocessors — with data residency, certifications, subprocessors lists, and exit plans.

24.2 Diligence themes

Security (SOC reports, penetration testing summaries), privacy (DPA, SCCs as applicable), availability SLAs, training-data use (opt-out of training on customer data where offered), incident notification, and concentration risk.

24.3 Ongoing monitoring

Track provider status, material contract changes, quality drift after provider updates, and alternative providers for critical path agents.

24.4 Exit / portability

Prompts, rules, taxonomies, and evaluation sets remain customer-owned artefacts under Evidence Room methodology. Avoid lock-in that prevents fallback to manual or alternate tooling.

25. Governance operating rhythm

Weekly AP ops huddle	Queues, escalations, defect spikes
Monthly Agent Performance Review	Scorecard, autonomy recommendations
Quarterly Control & Access Certification	SoD, access, control testing results
Release CAB (as needed)	Material workflow/model releases

Incident PIR	After Sev-1/2
--------------	---------------

Minutes and actions retained as programme evidence.

26. Related artefacts

Agent Control Matrix	`Governance/02_AGENT_CONTROL_MATRIX.md`
Observe-to-Scale Methodology	`Process_Mapping/01_OBSERVE_TO_SCALE_METHODODOLOGY.md`
Implementation Roadmap	`Process_Mapping/02_IMPLEMENTATION_ROADMAP.md`
Agent Performance Scorecard	`KPI_Measurement/01_AGENT_PERFORMANCE_SCORECARD.md`
Business Case Model	`Business_Case/01_AP_AGENT_BUSINESS_CASE_MODEL.md`
Shadow / Pilot / UAT	`Testing/01_SHADOW_PILOT_UAT.md`
Agent Library charters	`Agent_Library/`
Research Ledger (external claims)	`09_RESEARCH/`

27. Document control

1.0	—	Initial Professional tier release

Classification: Internal — client implementation use under licence **Disclaimer:** This framework is an operating toolkit. It does not constitute legal, audit, or regulatory advice. Local statutes, auditor requirements, and enterprise policies prevail where stricter.